The European Cybersecurity Strategy and the Role of Open Source Software

Madalin Neag
EU Policy Advisor@OpenSSF
The Linux Foundation
mneag@contractor.linuxfoundation.org

OpenSSF
OPEN SOURCE SECURITY FOUNDATION

Copyright © 2024 The Linux Foundation®. All rights reserved. The Linux Foundation has registered trademarks and uses trademarks.

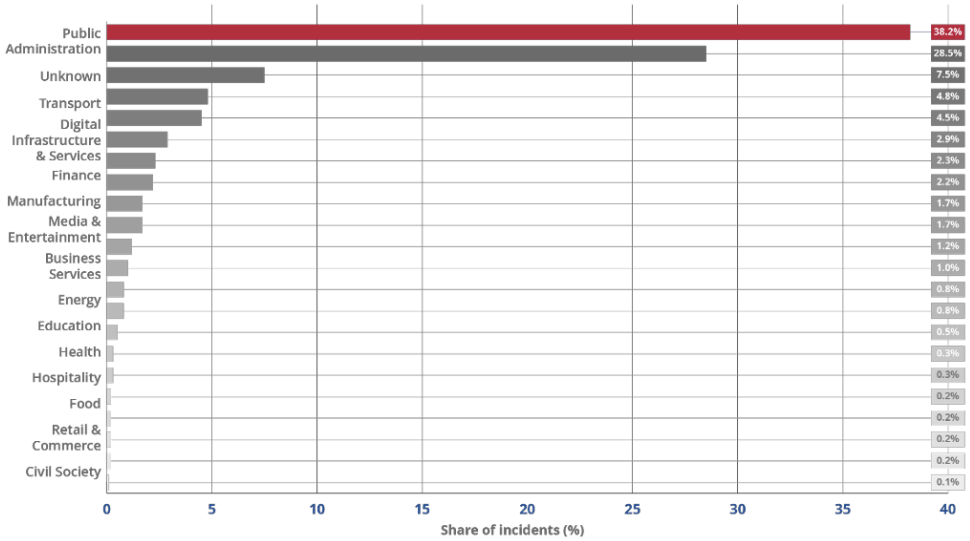
Agenda

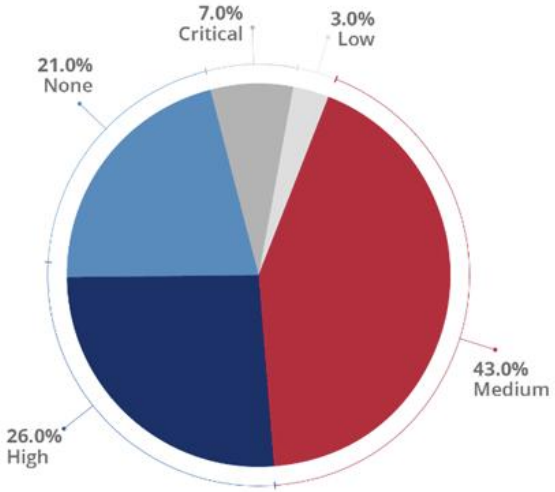
- The 2020 EU Cybersecurity Strategy
- The Regulatory Quartet: NIS2, DORA, RED DA & CRA
- The Critical Role of Open Source Software
- Conclusions

The 2020 EU Cybersecurity Strategy

OpenSSF
OPEN SOURCE SECURITY FOUNDATION

Cyber Threat Landscape





CVSS of vulnerabilities documented

- Supply chain hacks and zero day exploits can hit everything
- EU policies aim to strengthen resilience
- New regulations needed
  - Impacting also open source communities

$10.5T

estimated yearly cost of cybercrime in 2025

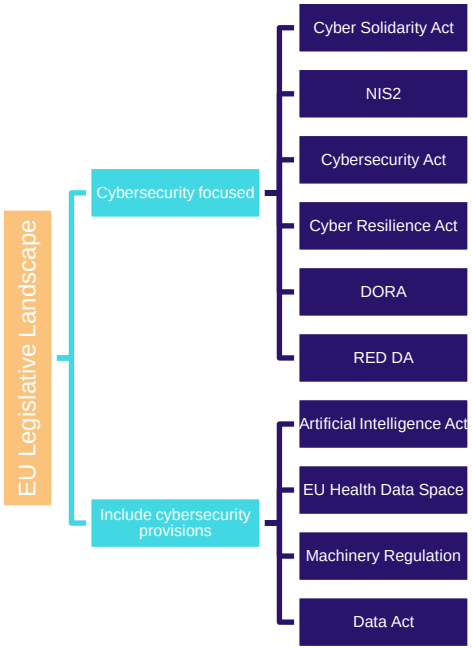
63%

of organizations cited complex and evolving threat landscape as their greatest challenge to becoming cyber resilient.

The 2020 EU Cybersecurity Strategy

The 2020 EU Cybersecurity Strategy strengthens protection for essential services and connected devices, enhances collective defense against major cyberattacks, and promotes global cooperation for security and stability in cyberspace.

- Strengthen EU resilience against cyber threats.
- Build collective operational capacity to detect and respond.
- Develop effective cyber deterrence measures.
- Enhance international cooperation and partnerships.
- Promote a global, open, and secure cyberspace.



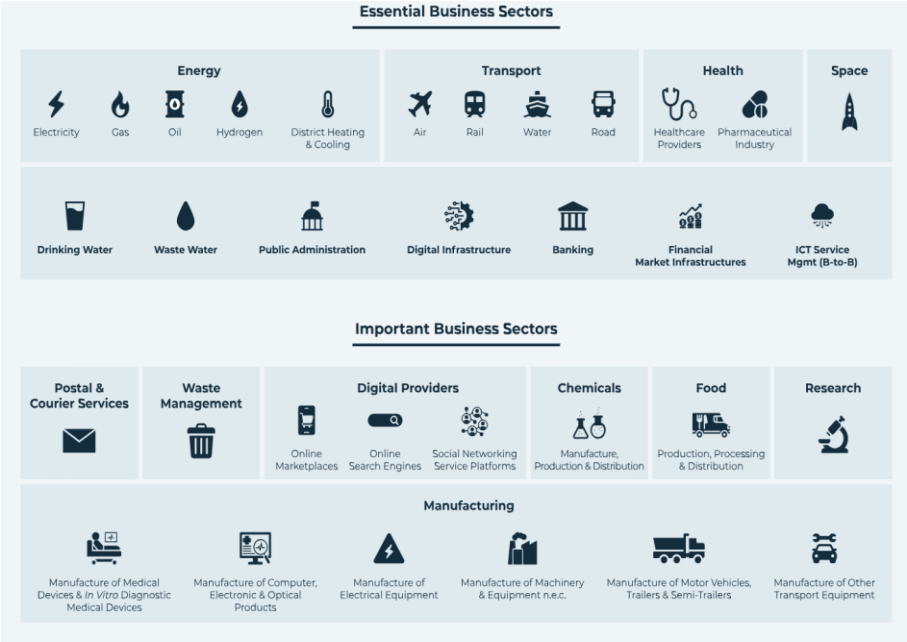
The need for comprehensive, harmonized rules to address the cross-border and cross-sectoral nature of cyber risk, replacing fragmented national laws

The Regulatory Quartet: NIS2, DORA, RED DA & CRA

OpenSSF
OPEN SOURCE SECURITY FOUNDATION

NIS2 Directive

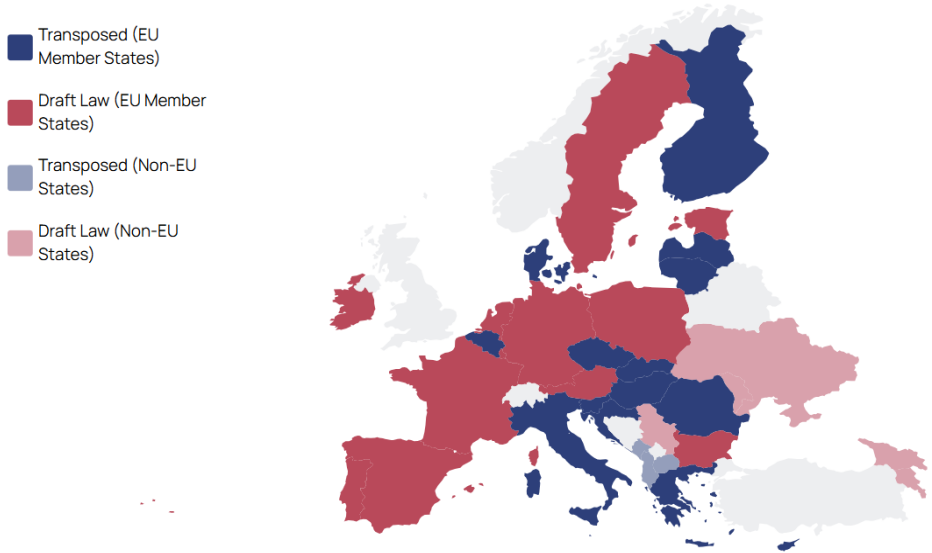
- Directive 2022/2555
- Repeals and replaces NIS1 directive
- Focus on
  - Service continuity
  - Enhancing overall network and information system security
  - Risk Management and Security Measures
  - Incident Reporting and Handling
  - Supply Chain Security
  - Cybersecurity Training and Awareness
- 18 critical sectors across the EU
- OSS used by critical infrastructure must meet compliance requirements
- Penalties (of total worldwide turnover)
  - Essential: EUR 10,000,000 or 2 %
  - Important: EUR 7,000,000 or 1.4%
- NIS2 Technical implementation guidance

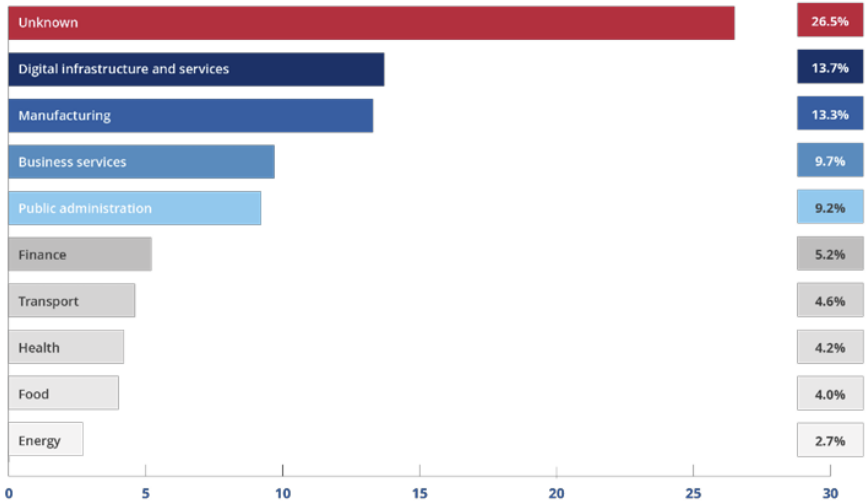


Interconnections between different sectors	Cascading effects of security incidents	Coordinated response capabilities	Information-sharing requirements	Joint exercise participation

https://www.datacore.com/blog/nis2-directive/

NIS2 Directive





15 out of 27 EU Member States have transposed the NIS2 Directive into national law.

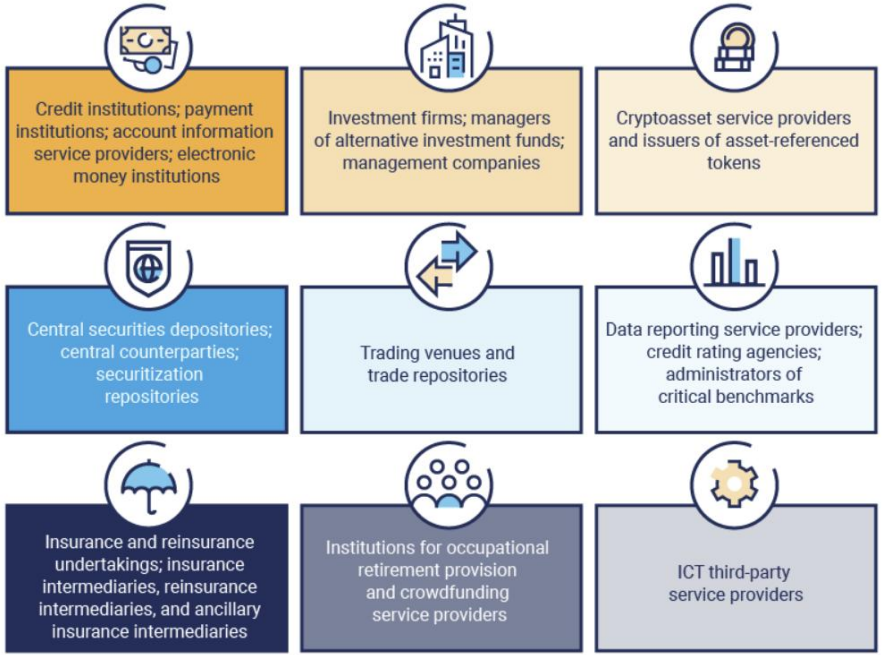
Create further fragmentation: Timelines, Enlarged Scope and Layered Entity Classification, Diverse International Security Frameworks

Cybercriminal activities continue to impact multiple sectors in the EU in both NIS2 and non-NIS2 sectors.

https://ecs-org.eu/activities/nis2-directive-transposition-tracker/
ENISA Threat Landscape 2025

DORA

- Digital Operational Resilience Act Regulation (EU) 2022/2554
- Application begins January 17, 2025
- Part of the EU's Digital Finance Package
- Lex Specialis (special law) for the entire EU Financial Area
- Pillars:
  - Comprehensive ICT Risk and Incident Management Framework
  - Incident reporting
  - Advanced Digital Operational Resilience
  - Strict oversight of critical ICT Third-Party Service Providers (e.g., Cloud providers)
  - Threat and Intelligence information sharing
- If DORA applies, NIS2 does not for the overlapping ICT risk management and incident reporting requirements
  - But it still applies for the other NIS2 provisions that are not covered by DORA
- OSS as part of ICT services must comply
- Encourage transparency and security assessment
- Fines up to
  - 2% of a financial entity's total annual worldwide turnover or €10 million
  - For CTPP, up to €5 million or 1% of average daily worldwide turnover for each day of non-compliance



DORA

Financial stability

Enhancing the operational resilience of financial institutions against ICT-related disruptions

Enhancing customer protection

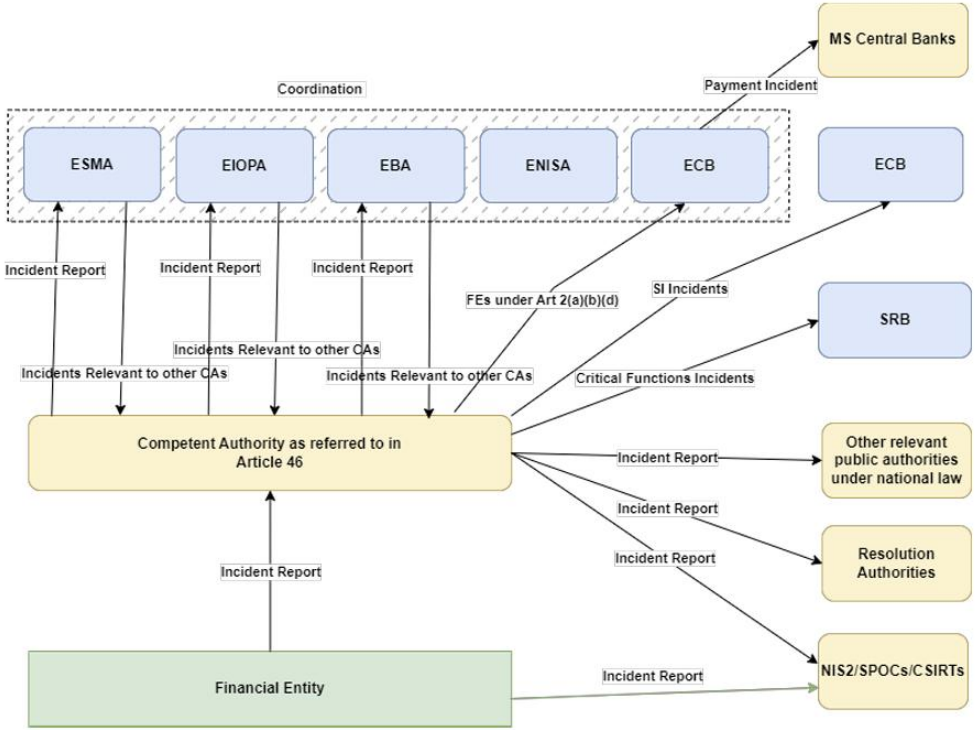
DORA enhances operational resilience and customer protection through secure, continuous digital financial services.

Promoting innovation and digital transformation

DORA's clear framework fosters secure innovation and digital transformation in finance

Encouraging cyber-resilient practices

DORA promotes a culture where staff competence and awareness strengthen cybersecurity and operational resilience.



RED DA

- Delegated Act (EU) 2022/30 under the Radio Equipment Directive (RED).
- Entering into force on August 1st, 2025
- Sets important cybersecurity requirements for manufacturers, importers and distributors of radio-enabled devices
- The following standards provide technical specifications for cybersecurity in internet-connected radio equipment:
  - EN 18031-1:2024 – Sets general cybersecurity requirements for internet-connected radio equipment.
  - EN 18031-2:2024 – Defines technical requirements for radio devices handling personal, traffic, or location data, including childcare, toy, and wearable equipment.
  - EN 18031-3:2024 – Covers cybersecurity requirements for radio equipment managing virtual or monetary value over the internet.
    -> foundation for the CRA-related standards

Key obligations - Art. 3.3 d, e, f

- The radio equipment does not harm network functionality or misuse resources.
- The personal data and the privacy for internet connected devices, such as wearable devices and toys, are protected.
- The devices handling virtual money or monetary value, securely process this data.

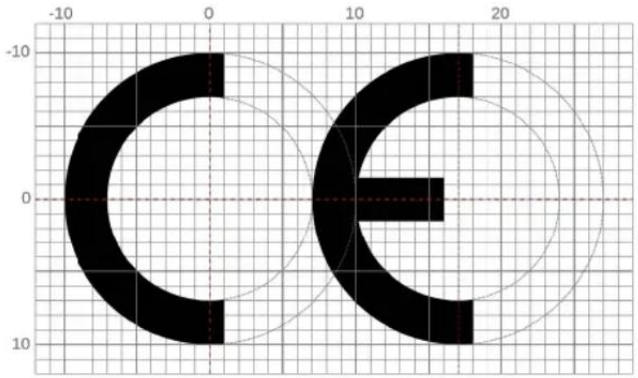
- Strengthen networks resilience
- Enhance consumers' security and privacy
- Prevent monetary fraud

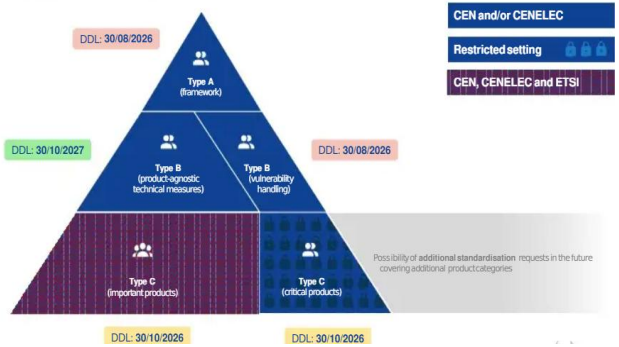
- Mobile phones, tablets, and other telecommunication devices.
- IoT connected products that can transmit or receive data.
- Smart toys and connected child gadgets, such as baby monitors.
- Wearable devices such as smartwatches or connected hearing aids.
- Connected smart meters, wireless sensors and more interconnected industrial devices.

https://www.onwardsecurity.com/en/lab_security-detail/redda/

Cyber Resilience Act (CRA)

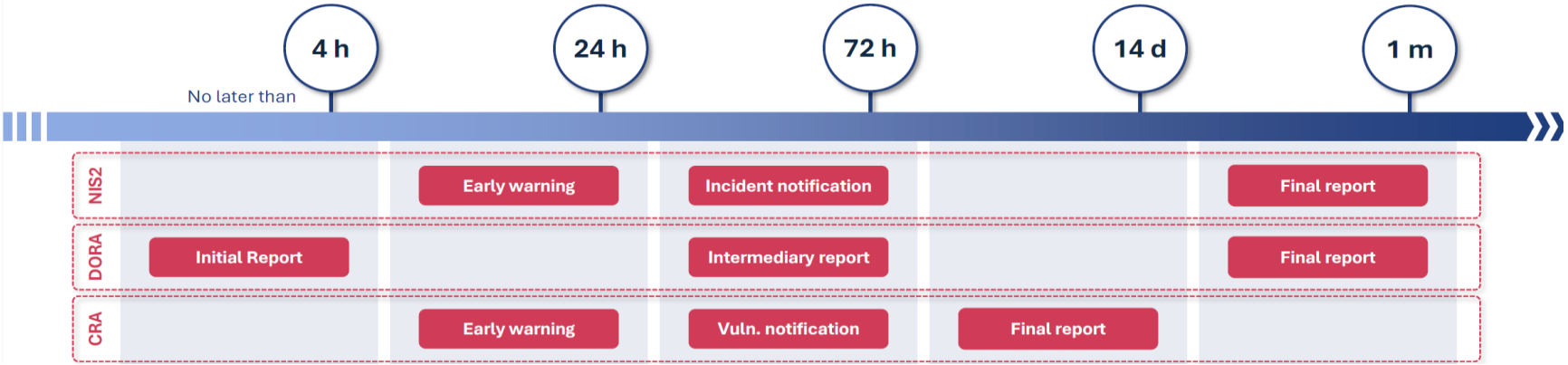
- Applies to nearly all Products with Digital Elements (PDEs), including hardware and software, placed on the EU market.
- Key elements:
  - Security must be "by design and by default,"
  - Vulnerability handling/disclosure processes,
  - Mandatory security updates throughout the product's lifecycle,
  - CE marking to indicate compliance.
- Conformity assessment differentiated by the product category
  - Reuse CSA certification to demonstrate conformity with CRA requirements
  - Obligation to use a CSA scheme for highly critical products
- Responsibility moves to the manufacturer (the entity placing the PDE on the market).
  - This includes securing all components used, including Open Source Software
  - Manufacturers are liable for the entire product, regardless of where the components originate
- Development of harmonised standards
- The CRA is broader than RED DA
  - Products covered by the RED DA cybersecurity provisions will eventually fall under the CRA when its main obligations apply (Dec 2027), establishir a single set of product rules.
  - RED DA will be repealed as of 11 December 2027

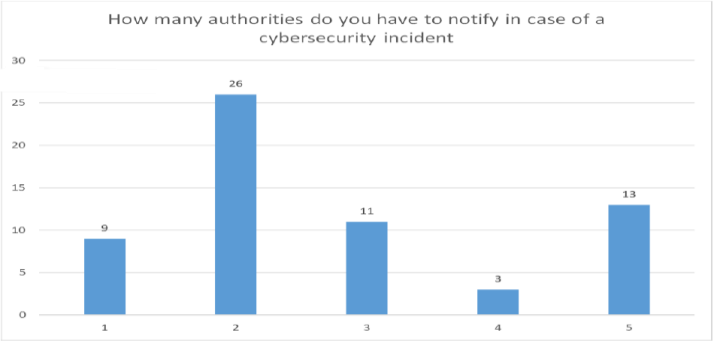




Complex requirements

Simplification via the Digital Omnibus?

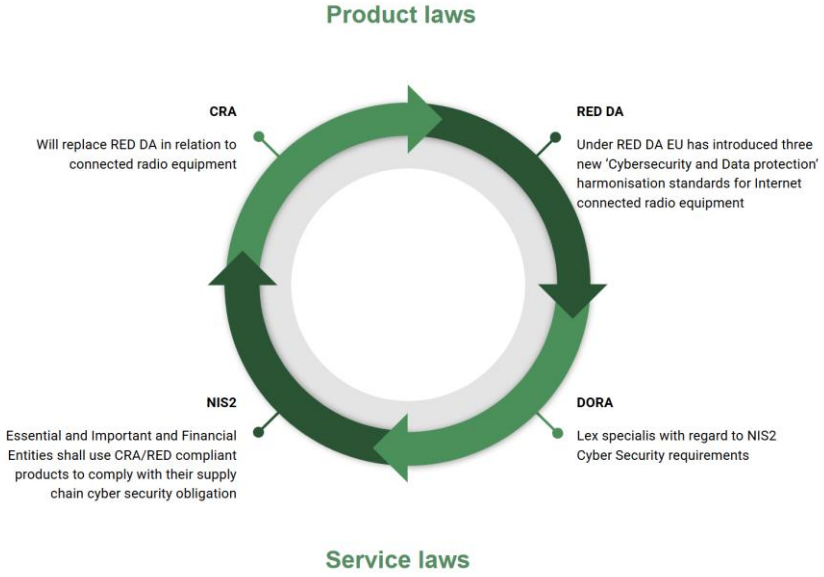




The most challenging areas to comply with include	
	Security requirements harmonization
	Risk analysis
	Data classification and endpoint management
	Vulnerability management
	Continuous monitoring
	Duplicative reporting towards national authorities
	Supply chain and security questionnaires
	Heavy compliance procedures, including audits and certifications.

Synergies and interoperability

1. Enhanced cybersecurity
2. Regulatory compliance
3. Customer trust & confidence
4. Operational resilience
5. Supply chain security
6. Incident reporting & response
7. Risk management



CRA/RED DA create a baseline of security for the devices/software used by entities under NIS2/DORA.

The compliance of manufacturers (CRA/RED DA) directly reduces the supply chain risk for critical service providers and financial institutions (NIS2/DORA).

All regulations place liability on management/manufacturers for cyber due diligence.

- Conduct risk assessments
- Review third-party relationships
- Develop and document incident response plans
- Implement reporting procedures
- Train staff regularly
- Document compliance efforts
- Engage with regulatory bodies

The Role of Open Source Software

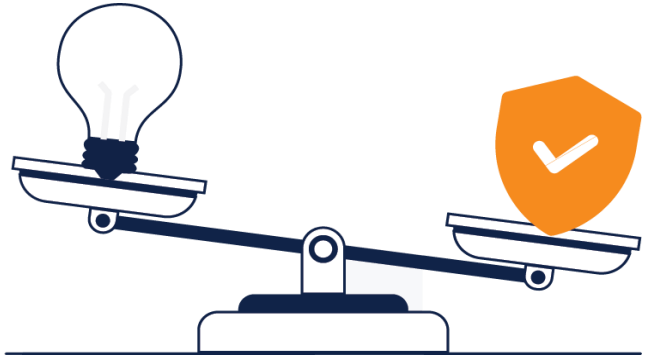
OpenSSF
OPEN SOURCE SECURITY FOUNDATION

The role of OSS

- Modern infrastructure - from cloud services (DORA/NIS2 scope) to embedded devices (CRA scope) - relies heavily on OSS.
- CRA, NIS2, and DORA intersect with OSS responsibilities
  - CRA regulates the security of the product (which integrates OSS)
  - NIS2/DORA regulate the security of the service and supply chain (which consume that product).
  - Result: If the CRA forces better security practices upstream in OSS component usage, it automatically improves the resilience of critical entities governed by NIS2 and DORA downstream.
- Advantages
  - Rapid innovation
  - Transparency and Trust: Open source software allows for public scrutiny, enhancing trust in cybersecurity measures.
  - Resilience Through Collaboration: Community-driven development leads to more robust and adaptable cybersecurity solutions.
- Risk: Single vulnerability (e.g., Log4Shell, XZ Utils) can have systemic impact across all sectors covered by CRA/NIS2/DORA

The role of OSS

- OSS Strategy 2020–2023:
  - Promote reuse in EU institutions
  - Engage with OSS communities
  - Support OSS sustainability
- Regulating OSS without stifling innovation
- Easing OSS compliance
  - Remove the ambiguity and fear for OSS
  - Guidelines & toolkits for security practices
  - Training & certification for OSS maintainers
- The CRA introduces OSS Stewards
  - A mechanism to foster security best practices in the OSS ecosystem without imposing disproportionate liability
  - Stewardship is a practical model for compliance and sustainability
  - Collaboration between policy makers and OSS stewards



The State of Global Open Source 2025
https://commission.europa.eu/about/departments-and-executive-agencies/digital-services/open-source-software-strategy_en
https://hyperproof.io/understanding-the-relationship-between-nis2-and-the-eu-cyber-resilience-act/

Baseline

European Commission

- Cyber Resilience Act
- DORA (forthcoming)
- NIS2 (forthcoming)

OpenSSF Open Source Project Security Baseline

Updated 27Feb2025

- Level 1 should contain criteria that would benefit any code or non-code project with any number of maintainers or users. (this definition is WIP)
- Level 2 should contain criteria that would benefit any code project that has at least 2 maintainers and a small number of consistent users. (this definition is WIP)
- Level 3 should contain criteria for any code project that has a large number of consistent users.

Category	ID	Control Statement	Objective	Requierment Statement	Maturity Level	Recommendations	OpenSSF Mappings: BP Badges	Scorecard Probe	Security Insights Value	SLSA	S2C2F	CRA	SSDF 1.1	NIST CSFv2	OpenChain ISO/IEC 18974:2023	OpenCRE
							link	link	link	link		link	link	link	link	link
Build & Release	OSPS-BR-03.02			When the project has a URI as an official distribution channel, that URI MUST be exclusively delivered using encrypted channels.		only fetch data from websites, API responses, and other services which use encrypted channels such as SSH or HTTPS for data transmission.										
Build & Release	OSPS-BR-04	All releases MUST provide a descriptive log of functional and security modifications.	Provide transparency and accountability for changes made to the project's software releases, enabling users to understand the modifications and improvements included in each release.			Ensure that all releases include a	CC-B-8, CC-B-9,			Choose an appropriate build platform, Follow a consistent build process, Build platform - Isolation strength - Isolated		1.2d, 1.2f, 1.2h, 1.2j, 1.2l, 2.5,	PS1, PS2, PS3, PW1.2	RS.AN-03	4.1.2	483-813, 068-486, 124-564, 757-271, 347-352, 263-184, 208-356, 745-356, 732-14
Build & Release	OSPS-BR-04.01															
Build & Release	OSPS-BR-05	All build and release pipelines MUST use standardized tooling where available to invest dependencies at build time.	Ensure that th release pipeli tools and proc dependencies compatibility i vulnerabilities									1.2b, 1.2d, 1.2f, 1.2h, 1.2j, 2.1, 2.2, 2.3	PO3.2, PS1, PS2			483-813, 124-564, 347-352,715-334
Build & Release	OSPS-BR-05.01															
Build & Release	OSPS-BR-06	Produce all released software assets with signatures and hashes.	All released s be signed or a signed manife asset's crypto										PO5.2, PS2, PS2.1, PW6.2			
Build & Release	OSPS-BR-06.01															
Documentation	OSPS-DO-01	The **project documentation** MUST provide user guides for all basic functionality.	Ensure that u comprehensiv project's curre									1.2b, 1.2j, 1.2k	PW1.2	GV.OC-04, GV.OC-05	4.1.4	036-275

OSPS-BR-04 - All releases MUST provide a descriptive log of functional and security modifications.

Provide transparency and accountability for changes made to the project's software releases, enabling users to understand the modifications and improvements included in each release.

OSPS-BR-04.01

Requirement: When an official release is created, that release MUST contain a descriptive log of functional and security modifications.

Recommendation: Ensure that all releases include a descriptive change log. It is recommended to ensure that the change log is human-readable and includes details beyond commit messages, such as descriptions of the security impact or relevance to different use cases. To ensure machine readability, place the content under a markdown header such as "## Changelog".

- Maturity Level 2
- Maturity Level 3

External Framework Mappings

- **BPB**: CC-B-8, CC-B-9
- **CRA**: 1.2l, 2.2
- **SSDF**: PS1, PS2, PS3, PW1.2
- **OCRE**: 486-813, 124-564, 745-356

LEVEL 2 & 3

The Baseline includes a Catalog of requirements that map to industry standards, frameworks, and regulations, and Tooling to assist in determining Baseline-compliance, that automate Baseline configuration settings, and links to evidence and attestations.

Conclusions

Final considerations

- Together, DORA, NIS2, RED DA, and the CRA form a comprehensive framework aimed at:
  - enhancing the EU's resilience to cyberattacks
  - ensuring operational stability across critical sectors and infrastructures.
- If you set up separate compliances programmes for each, you'll end up in a tangle.
  - The work you do to comply with one regulation will support your compliance with others, provided you see them as something that comes together as a whole.
  - Similarly, think about how the timelines for compliance interact, and make them work for you.
- Aligning OSS practices with EU cybersecurity policies strengthens trust, transparency, resilience, and innovation
  - OSS communities adopt security best practices
  - Funding & tools to support critical OSS projects
  - Create tools, processes and guidelines to help OSS communities navigate this complex landscape

Open source **security requires cross-industry collaboration**, where manufacturers, governments, & projects co-develop policies, fund security, & ensure long-term software maintenance.

Final considerations

- Actionable items for companies
  - Identify Scope: Which laws apply? (NIS2 or DORA? If you sell software, CRA?).
  - Audit Supply Chain: Inventory all software (especially OSS) to create SBOMs.
  - Elevate Governance: Make cybersecurity an Executive Board agenda item (mandatory under NIS2/DORA).
  - Embrace open source stewardship to enhance cybersecurity resilience
  - Invest Upstream: Support the security hardening of critical OSS components
- Actionable items for simplification
  - Align reporting platforms and timelines
  - Standardized templates for due diligence, risk management, vulnerability & incident reporting
  - Practical implementation guidelines on conformity assessments

Complexity vs usefulness

69%

of GCO survey respondents find regulations too complex or too numerous, or have difficulty verifying whether third-party suppliers are compliant.

vs

Thank you very much

Ways to Participate

- Join a Working Group/Project
- Come to a Meeting (see Public Calendar)
- Collaborate on Slack
- Contribute on GitHub
- Become an Organizational Member
- Keep up to date by subscribing to the OpenSSF Mailing List

OpenSSF
OPEN SOURCE SECURITY FOUNDATION

Legal Notice

Copyright © Open Source Security Foundation®, The Linux Foundation®, & their contributors. The Linux Foundation has registered trademarks and uses trademarks. All other trademarks are those of their respective owners.

Per the OpenSSF Charter, this presentation is released under the Creative Commons Attribution 4.0 International License (CC-BY-4.0), available at <https://creativecommons.org/licenses/by/4.0/>. You are free to:

- Share — copy and redistribute the material in any medium or format for any purpose, even commercially.
- Adapt — remix, transform, and build upon the material for any purpose, even commercially.

The licensor cannot revoke these freedoms as long as you follow the license terms:

- Attribution — You must give appropriate credit , provide a link to the license, and indicate if changes were made . You may do so in any reasonable manner, but not in any way that suggests the licensor endorses you or your use.
- No additional restrictions — You may not apply legal terms or technological measures that legally restrict others from doing anything the license permits.